

ACRS

تصميم وتقييم نموذج احتواء سيبراني يتكيف مع خطورة الهجوم وأهمية الجهاز

ACRS: نظام الاستجابة السيبرانية المتكيفة • يوقف الهجوم... لا المستشفى

36 = 36

أوقف المهاجم (من 41)

7 → 2

أنظمة مهمة توقفت

37 → 20

أجهزة توقفت

بحث وتطوير: حسان عبدالله الينبعاوي

كل البيانات في هذه الورقة من محاكاة. لم تُلمس أي شبكة حقيقية.

كل البيانات في هذه الورقة من محاكاة. لم تُلمس أي شبكة حقيقية.

نتيجة مهمة

مشكلة أو تحذير

ما يضيفه ACRS

الملخص

عندما يُخترق جهاز في منشأة، تعزله أغلب أنظمة الرد الآلي عزلاً كاملاً عن الشبكة. هذا يوقف المهاجم، لكنه **قد يوقف معه خادم الدخول الذي يعتمد عليه كل الموظفين، أو جهازاً طبياً يعتمد عليه مريض**. يقترح هذا البحث نظاماً اسمه ACRS **يختار أخف رد يكفي لإيقاف المهاجم**، بناءً على ثلاثة أشياء: خطورة الهجوم، ومدى التأكد منه، وأهمية الجهاز. قارنًا ACRS بالطريقة المعتادة، وهي عزل كامل لأي جهاز تتجاوز خطورته 60، في تجربة محاكاة من 42 حادثة وبنفس المدخلات تمامًا. النتيجة: **توقف 20 جهازاً بدل 37، وتوقف نظامان مهمان بدل 7، وأوقف المهاجم في 36 هجوماً من 41 في الطريقتين**. ولم ينجح أي رقم ثابت بين 50 و100 في تحقيق النتيجة. وفي تجربة ثانية من 8 جولات يغيّر فيها المهاجم أسلوبه، **نجحت كل خدعة جديدة مرة واحدة فقط** بعد أن تعلّم ACRS من رد المهندس. **الثمن هو تدخل بشري في مواضع محددة**.

كلمات مفتاحية: الاستجابة للحوادث، الاحتواء، الرد الآلي، أهمية الأصول، الفدية

1 المقدمة والمشكلة

الهجمات الإلكترونية صارت أسرع وأخطر. في تقارير Verizon السنوية، ارتفعت نسبة الاختراقات التي فيها برامج فدية **من 25% في 2022 إلى 48% في 2026** [1]. وتقول CrowdStrike إن متوسط الوقت الذي يحتاجه المهاجم لينتقل من أول جهاز إلى أجهزة أخرى كان **29 دقيقة** في 2025 [2]. ومتوسط تكلفة الاختراق عالمياً **4.99 مليون دولار** [3].

لأن المهاجم سريع، تعتمد المنشآت على أنظمة رد آلي تتحرك في ثوانٍ بدل انتظار إنسان. والرد الأشهر في هذه الأنظمة بسيط: **عزل الجهاز المصاب عزلاً كاملاً عن الشبكة**.

المشكلة أن هذا الرد واحد لكل الأجهزة. عزل جهاز موظف لا يضر أحداً، **لكن عزل خادم الدخول يوقف كل الموظفين، وعزل جهاز طبي قد يضر مريضاً**. وإرشادات الاستجابة للحوادث توصي أصلاً بأن يراعي قرار الاحتواء أثره على الخدمات [4]. إذن السؤال ليس: هل نوقف المهاجم؟ بل: **ما أخف رد يكفي لإيقافه؟**

2 سؤال البحث والفرضية

سؤال البحث: هل يمكن لنظام يوازن بين خطورة الهجوم وأهمية الجهاز أن يوقف أجهزة أقل من العزل الكامل، ويوقف المهاجم بنفس القوة؟

الفرضية: النظام الذي يراعي أهمية الجهاز يوقف أجهزة أقل وأنظمة مهمة أقل، دون أن يقل عدد الهجمات التي يوقف فيها المهاجم.

الفرضية الصفرية: لا فرق في عدد الأجهزة المتوقفة، أو أن ACRS يوقف المهاجم في عدد أقل من الهجمات.
الأهداف:

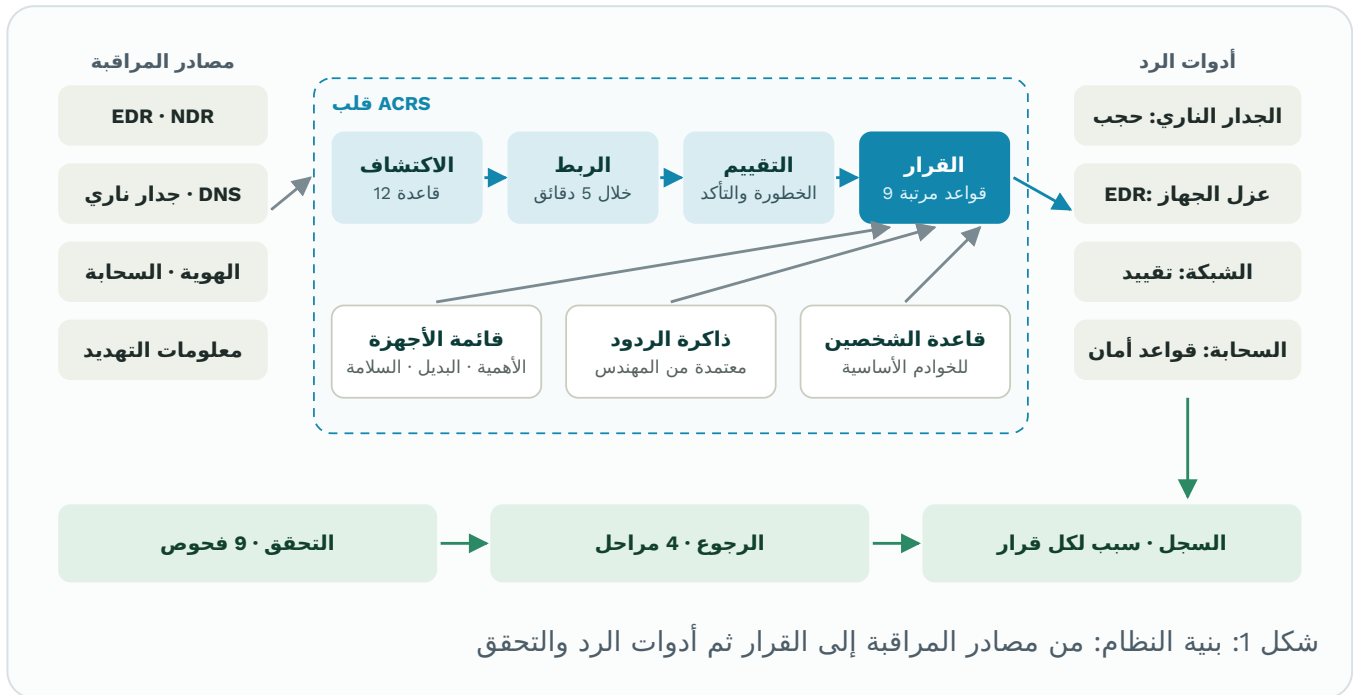
1. بناء ACRS كنظام قرار بقواعد واضحة يمكن فحصها وشرح كل قرار فيها.
2. اختياره أمام العزل الكامل على نفس الهجمات المحاكاة.
3. قياس عدد الأجهزة المتوقفة، وإيقاف المهاجم، والسرعة، والجهد البشري المطلوب.

3 كيف يعمل ACRS

يمر كل تنبيه في ACRS بثماني مراحل. التجربة تغيّر المرحلة الخامسة فقط، أي القرار:

1. الاكتشاف: 12 قاعدة تقرأ من 8 أنواع من الحساسات.
2. الربط: جمع الأحداث المرتبطة خلال 5 دقائق في حادثة واحدة.
3. حساب الخطورة: درجة من 0 إلى 100 من 6 عوامل.
4. أهمية الجهاز: هل هو أساسي أو مهم أو عادي؟ هل له بديل؟ هل هو جهاز سلامة؟
5. القرار: 9 قواعد مرتبة، بدون ذكاء اصطناعي.
6. الاحتواء: تنفيذ الأمر خلال مهلة 7 أو 15 أو 90 ثانية حسب أهمية الجهاز.
7. التحقق: 9 فحوص تتأكد أن الاحتواء نجح.
8. الرجوع: يعود الجهاز للعمل على مراحل.

الأجهزة في ACRS ثلاثة مستويات: أساسية (Tier-0) مثل خوادم الدخول والشهادات، ومهمة (Tier-1) مثل قواعد البيانات والأجهزة الطبية، وعادية (Tier-2) مثل أجهزة الموظفين.



قواعد القرار التسع بالترتيب، وأول قاعدة تنطبق هي التي تحكم:

#	إذا كان...	فإن ACRS...
1	الجهاز غير معروف	يجب عنوانه عند حدود الشبكة فقط
2	الجهاز لا يجوز إطفائه (طبي أو صناعي)	يجب المهاجم من الشبكة ويترك الجهاز يعمل
3	الهجوم فدية	يتحرك فوراً: الأساسي يُقَيّد، والمهم يُعزل ويعمل بديله، والعادي يُعزل كاملاً
4	التأكد أقل من 60% (وحساس واحد لا يتجاوز 55%)	لا يعزل وحده، وينتظر إنساناً
5	الخطورة أقل من 60	يراقب فقط
6	الجهاز في وقت صيانة معتمد	يُقَيّد وينتظر تأكيداً
7	الخطورة فوق حد الجهاز (أساسي 95، مهم 90، عادي 85)	أساسي: تقييد فوري وشخصان للعزل الكامل. مهم: عزل والبديل يعمل. عادي: عزل كامل
8	الخطورة متوسطة	يُقَيّد وحده، والخطوة الأقوى تحتاج إنساناً. الأساسي: مراقبة وشخصان
9	حصلت 5 احتواءات آلية أو أكثر خلال 10 دقائق	يوقف الآلية مؤقتاً حتى لا يعزل المنشأة كلها

ما يضيفه ACRS: العزل الآلي موجود في أدوات الأمن التجارية، ولا ندّعي أننا اخترعناه. ما يضيفه هذا البحث هو نموذج قرار واضح يحدد قوة الرد من الخطورة والتأكد وأهمية الجهاز، وتجربة مضبوطة تقارنه بالعزل الكامل.

4 طريقة التجربة

التجربة من ذراعين: كل حادثة تمر على الطريقتين بنفس المعلومات تمامًا، أي نفس الاكتشاف ونفس درجة الخطورة ونفس درجة التأكد. **الشيء الوحيد المختلف هو القرار.**



شكل 2: تصميم التجربة: مجموعة ضابطة ومجموعة تجريبية بنفس المدخلات

الطريقة المعتادة (خط الأساس): إذا كانت الخطورة 60 أو أكثر، أو الهجوم فدية سريعة، يُعزل الجهاز عزلاً كاملاً فوراً. غير ذلك: مراقبة. اخترنا 60 لأنه نفس الحد الأدنى الذي يستخدمه ACRS، حتى تكون المقارنة عادلة.

النوع	المتغير
المستقل (ما غيّرناه)	طريقة الرد: الطريقة المعتادة أو ACRS
التابع (ما قسناه)	الأجهزة المتوقفة، الأنظمة المهمة المتوقفة، الأجهزة الطبية المطفأة، الخوادم الأساسية المعزولة دون إنسان، الحالة السليمة، إيقاف المهاجم، الطرق المقطوعة، سرعة الرد، الجهد البشري
الثابت	نفس السيناريوهات، ونفس الاكتشاف، ونفس حساب الخطورة والتأكد، ونفس قائمة الأجهزة، ونفس طريقة تحويل القرار إلى أوامر، ونفس طريقة العد

البيانات: 40 سيناريو هجوم في 8 أنواع، نتجت عنها 42 حادثة: 41 هجومًا وحالة سليمة واحدة (عمل صيانة مشروع يشبه الهجوم). الأجهزة 20: 4 أساسية، و10 مهمة منها جهاز رنين مغناطيسي، و6 عادية. تراوحت الخطورة بين 40 و99، ورأى كل حادثة من 1 إلى 4 حساسات.

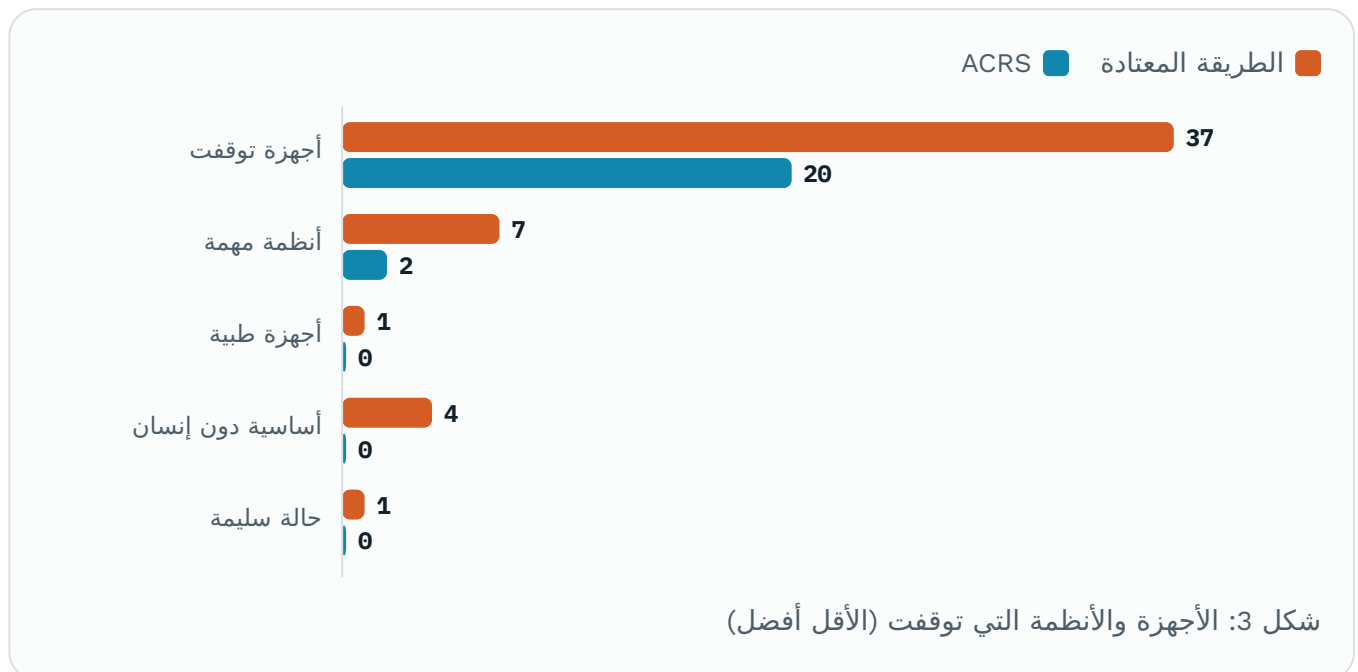
نوع الهجوم	عدد الحوادث
فدية	7
اتصال بخادم المهاجم	6
سرقة هوية ودخول	5
دخول أولي	5
حالات خاصة	5
سحابة وحاويات	5
تطبيقات ويب	5
تسريب من الداخل	4

طريقة العد: لا نعدّ من اسم القرار، بل من الأوامر التي أصدرتها كل طريقة فعليًا. مثلاً: نقول إن المهاجم أوقف فقط إذا صدر أمر يقطع اتصاله بالخارج.

إعادة الإنتاج: النظام لا يعتمد على العشوائية، لذلك إعادة التجربة **تعطي نفس الأرقام تمامًا**. وبصمة ملف القواعد 87893ca0، و6 اختبارات آلية تتأكد في كل تشغيل أن النتائج لم تتغير.

جدول 1: النتائج الرئيسية على 42 حادثة

مادا قسنا	الطريقة المعتادة	ACRS
أجهزة توقفت عن العمل	37	20
أنظمة مهمة توقفت	7	2
أوقف المهاجم (من 41 هجومًا)	36	36
طرق مقطوعة نحو الأنظمة المهمة	36	30
أجهزة طبية أطفئت	1	0
خوادم أساسية عُزلت دون قرار إنسان	4	0
حالة سليمة أوقفت بالخطأ	1	0

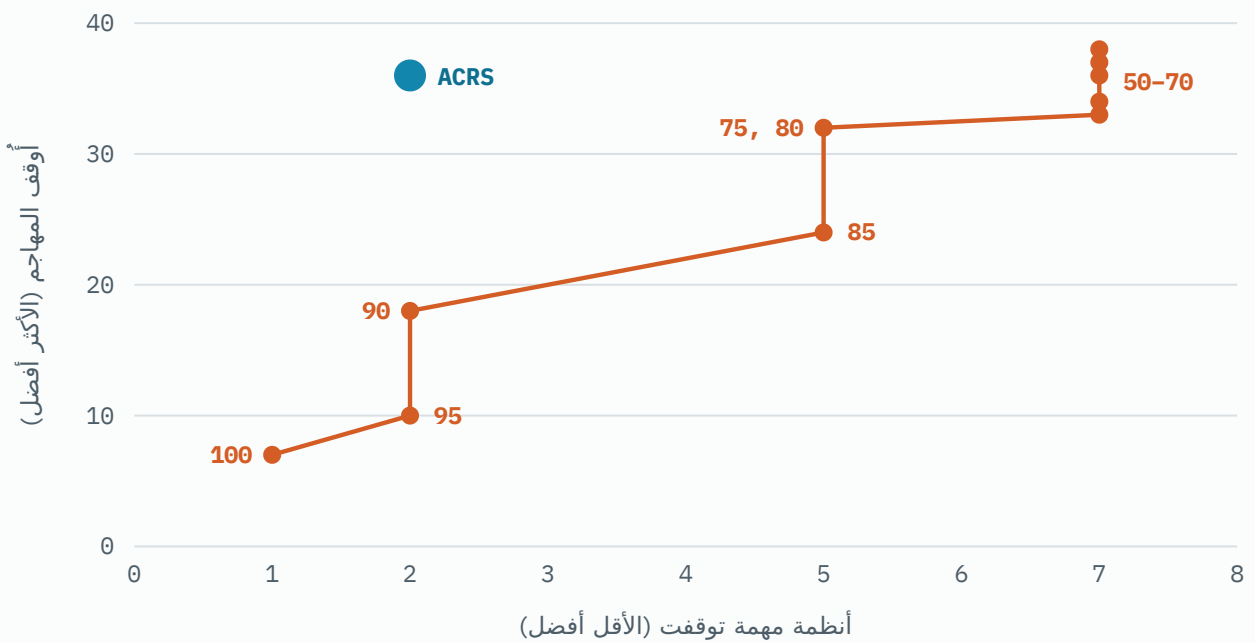


أوقف ACRS المهاجم في نفس عدد الهجمات (36 من 41)، لكنه أوقف 20 جهازًا بدل 37، أي أقل بـ 46%. ونزلت الأنظمة المهمة المتوقفة من 7 إلى 2.

هل يكفي رفع رقم العزل في الطريقة المعتادة؟ جربنا كل الأرقام من 50 إلى 100:

جدول 2: الطريقة المعتادة بأرقام عزل مختلفة

رقم العزل	أنظمة مهمة توقفت	أوقف المهاجم
50	7	38
55	7	37
60	7	36
65	7	34
70	7	33
75, 80	5	32
85	5	24
90	2	18
95	2	10
100	1	7
ACRS	2	36



شكل 4: كل نقطة برتقالية هي الطريقة المعتادة برقم عزل مختلف

للوصول إلى نظامين مهمين متوقفين فقط، تحتاج الطريقة المعتادة رقم 90، وعندها **لا يُوقف المهاجم إلا في 18 هجوماً . ACRS وحده حقق 2 و36 معًا .**

قرارات ACRS على الـ42 حادثة: 17 تقييد والجهاز يعمل، و9 عزل ذكي، و7 عزل كامل، و4 تقييد فوري، و4 مراقبة، وحالة واحدة حجب من الشبكة فقط. أما الطريقة المعتادة فعزلت 37 عزلاً كاملاً وراقبت 5. السرعة: في 5 تشغيلات كاملة كان زمن الاحتواء **بين 0.29 و0.34 ثانية في الطريقتين**، ولم يتأخر أي احتواء عن مهلته في 365 عملية. والقرار نفسه يأخذ نحو 2 ميكروثانية في ACRS، و0.8 في الطريقة المعتادة. أي أن الفرق في الوقت لا يُذكر.

6 التجربة الثانية: لا يوجد معنى للفشل

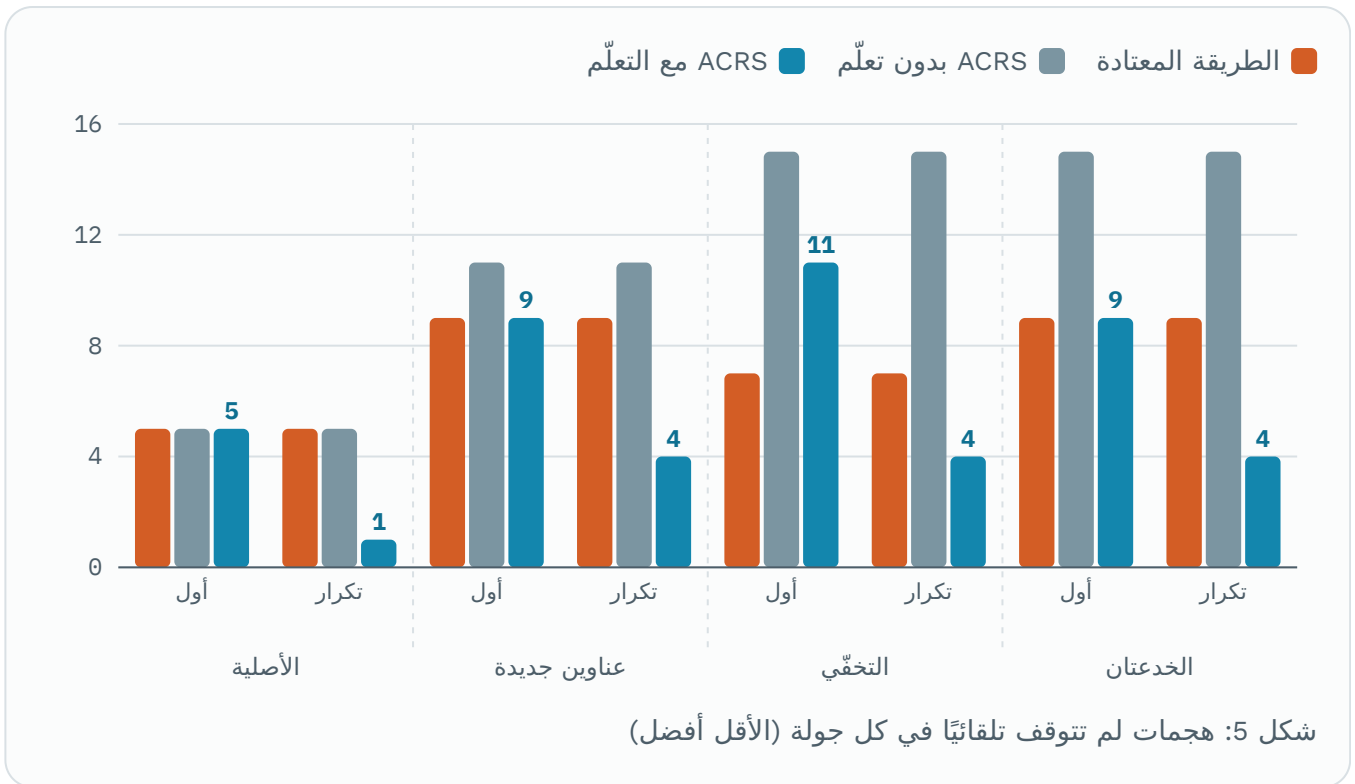
إذا لم يوقف ACRS هجوماً تلقائياً، يتدخل المهندس بيده. سؤال هذه التجربة: **إذا حفظ ACRS رد المهندس واستخدمه مع الهجمات المشابهة، كم هجوماً يفلت عندما تعود نفس الهجمات، حتى لو غيّر المهاجم أسلوبه؟**

الطريقة: 8 جولات، في كل جولة نفس الـ41 هجوماً، ويغيّر المهاجم أسلوبه كل جولتين: الهجمات الأصلية، ثم عناوين جديدة لا تعرفها قوائم التهديدات، ثم التخفي عن أحد الحساسات، ثم الخدعتان معًا. كل نسخة تمر على نفس محركات النظام بدون تعديل. بعد كل جولة، كل هجوم لم يتوقف تلقائياً يعالجه المهندس (محاكى، ونفترض أنه يعرف الهجوم صح)، ويحفظ رده.

ضوابط الأمان في الرد المتعلم: يُستخدم فقط إذا تشابه الهجوم الجديد مع رد معتمد بنسبة 96% أو أكثر، ولا يُستخدم أبداً على خادم أساسي، وأقوى ما يفعله هو التقييد والجهاز يعمل (أو الحجب من الشبكة لجهاز لا يُطفأ). لا يعزل أي جهاز.

جدول 3: هجمات لم تتوقف تلقائياً (من 41) في كل جولة

الجولة	الطريقة المعتادة	ACRS بدون تعلّم	ACRS مع التعلّم
1: الهجمات الأصلية	5	5	5
2: تكرار	5	5	1
3: عناوين جديدة	9	11	9
4: تكرار	9	11	4
5: التخفي عن حساس	7	15	11
6: تكرار	7	15	4
7: الخدعتان معًا	9	15	9
8: تكرار	9	15	4



النتيجة: كل خدعة جديدة نجحت مرة واحدة فقط. في كل جولة تكرار نزل العدد إلى 4، والأربعة كلها خوادم أساسية ينتظر فيها ACRS قرار إنسان عن قصد. أي أن الهجمات التي تفلت في بقية الأجهزة وصلت إلى صفر. ولم يُستخدم الرد المتعلّم ولا مرة على الحالة السليمة ولا على خادم أساسي.

ملاحظة مهمة: بدون تعلّم، الخدع ترفع ما يفلت من ACRS إلى 15، أكثر من الطريقة المعتادة (9)، لأن ACRS لا يتصرف وحده عندما يقل التأكد. التعلّم هو ما يعالج هذا الضعف عند تكرار الهجوم. والخدعة الجديدة لا تُكشف من أول مرة: يحتاج المهندس أن يراها مرة.

التجربة في `research/learning.py`، ومعه 3 اختبارات آلية، وتعطي نفس الأرقام في كل تشغيل.

7 المناقشة

لماذا نجح ACRS؟ لأنه لا يعامل كل الأجهزة بنفس الطريقة. الجهاز العادي يُعزل كاملاً كما في الطريقة المعتادة. أما الخادم الذي له بديل فيُعزل والعمل ينتقل للبديل، والجهاز الطبي لا يُطفأ ويُحجب المهاجم من الشبكة، والخادم الأساسي لا يُعزل عزلاً كاملاً أبداً دون موافقة شخصين.

الثنى الأول: قطع ACRS طرقاً أقل نحو الأنظمة المهمة (30 بدل 36). هذا مقصود: 4 خوادم أساسية تنتظر موافقة شخصين، وجهاز طبي لم يُطفأ، وتنبيه رآه حساس واحد فقط. لكنه تنازل حقيقي ونذكره بوضوح.

الثنى الثاني: الجهد البشري. يؤكد شخص رجوع الجهاز في 16 حالة، وتنتظر 4 خوادم أساسية موافقة شخصين، وحالتان تنتظران إنساناً قبل أي احتواء (الحالة السليمة وتنبيه الحساس الواحد). الطريقة المعتادة لا تحتاج أحداً، لكنها تعزل خوادم أساسية دون أي قرار بشري.

ما زال ACRS يوقف نظامين مهمين: قاعدة بيانات ERP-DB-01 وخادم الشهادات PKI-CA-01. هذان جهازان بلا بديل وكان الخطر عليهما عالياً.

1. البيانات محاكاة: 40 سيناريو على 20 جهازًا افتراضيًا.
2. أثر التوقف محسوب من وصف الأجهزة، وليس مقاسًا على خدمات تعمل فعليًا.
3. أوزان الخطورة محددة بالتصميم، ولم تُضبط على هجمات حقيقية.
4. **نفس الشخص كتب السيناريوهات والقواعد، وهذا قد يميل لصالح ACRS.** وهذا أهم قيد في البحث.
5. زمن الاحتواء مقاس على أدوات محاكاة بزمن واقعي، وليس على أدوات حقيقية.
6. ACRS يقطع طرقًا أقل (30 بدل 36)، وهذا تنازل مقصود لكنه حقيقي.
7. في تجربة التعلّم، المهندس محاكى ونفترض أنه يعرف الهجوم صح، والخدع مولّدة من نفس الهجمات وليست هجمات جديدة كليًا.

9 العمل المستقبلي

- تجربة قراءة فقط على تنبيهات حقيقية: يقرر ACRS ويسجل قراره ولا ينفذ، ثم تُضبط الأوزان.
- سيناريوهات هجوم يكتبها أشخاص آخرون، وتُشغّل دون تعديل القواعد، لإزالة تحيّز الكاتب الواحد.
- ربط أداة حماية حقيقية واحدة في بيئة اختبار.
- نسخة أساسية مجانية، مع دعم مدفوع للمستشفيات والشركات الصغيرة.

10 الخلاصة

في هذه المحاكاة، الرد على قدر الخطر **أوقف أجهزة أقل بـ 46%**، وأنظمة مهمة أقل (2 بدل 7)، وأوقف المهاجم بنفس القوة، وبنفس السرعة. ولم يستطع أي رقم عزل ثابت الوصول لنفس النتيجة. ومع التعلّم من المهندس، لم تنجح أي خدعة أكثر من مرة واحدة. لذلك **تحققت الفرضية في هذه المحاكاة**، والخطوة التالية اختبارها على بيانات حقيقية وسيناريوهات يكتبها غيري.

المراجع

1. Verizon. Data Breach Investigations Report 2022–2026. نسبة الاختراقات التي فيها فدية: 25%، 24%، 32% (مع أساليب الابتزاز الأخرى)، 44%، 48%.
2. CrowdStrike. 2026 Global Threat Report. متوسط زمن انتشار المهاجم 29 دقيقة (2025).
3. IBM. Cost of a Data Breach Report 2026. متوسط تكلفة الاختراق عالميًا 4.99 مليون دولار.
4. NIST SP 800-61 Rev 2 (2012) و Rev 3 (2025). إرشادات الاستجابة للحوادث.
5. NIST SP 800-207 (2020). Zero Trust Architecture.
6. MITRE ATT&CK, Enterprise Matrix (T1486, T1490).
7. الهيئة الوطنية للأمن السيبراني. الضوابط الأساسية للأمن السيبراني (ECC).

